

개인정보 보호조치 안내서

주요 위반 · 개선 사례 중심



개인정보보호위원회



한국인터넷진흥원

|| 목 차 ||

1. 개인정보 수집·이용	1
2. 개인정보 파기	3
3. 고유식별정보 처리	5
4. 개인정보 처리 업무위탁	7
5. 개인정보 안전조치	9
5.1. 개인정보취급자 접근권한 관리	9
5.2. 비인가자 접근통제	11
5.3. 고유식별정보 암호화	13
5.4. 비밀번호 암호화	15
5.5. 접속기록 보관·관리	17

- 본 안내서의 저작권은 개인정보보호위원회에 있음
- 본 안내서는 개인정보보호법에 따라 개인정보처리자가 준수해야할 사항 중 주요 위반사례 및 조치방법을 안내함
- 누구나 개인정보보호 교육 및 안내 등의 목적으로 이 안내서를 활용(인용·편집 포함) 할 수 있으며, 이 경우 다음과 같이 출처 및 저작권 표시를 하여야 함.
※ 출처 : 개인정보보호위원회, 개인정보 보호조치 안내서(2020.12.)

1. 개인정보 수집·이용

< 위반 사례 >

- 별도의 수집 근거가 없음에도 정보주체의 동의를 받지 않고 개인정보를 수집한 사례
→ 개인정보를 수집을 위한 별도의 법적 근거가 없는 경우, 수집·이용에 대한 정보주체의 동의를 받은 뒤 수집해야 함
- 개인정보 수집 시 정보주체로부터 수집 동의를 받았으나, 필수 고지사항 중 '개인정보 보유 및 이용 기간'을 누락한 사례
→ 개인정보 수집·이용을 위한 동의를 받을 때는 '① 개인정보 수집·이용 목적, ② 수집하려는 개인정보의 항목, ③ 개인정보의 보유 및 이용 기간, ④ 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용'을 반드시 고지해야 함

조치 사항 및 방법

▶ 정보주체의 동의 획득

개인정보처리자는 정보주체의 동의를 받은 경우 등에 개인정보를 수집할 수 있으며, '동의'는 개인정보처리자가 개인정보를 수집·이용하는 것에 대한 정보주체의 자발적인 승낙의 의사표시로서 동의여부를 명확하게 확인할 수 있어야 합니다.

가입신청서 등의 서면에 직접 자신의 성명을 기재하고 인장을 찍는 방법 또는 자필 서명하거나, 인터넷 웹사이트 화면에서 '동의' 버튼을 클릭하는 등으로 동의의 의사표시를 할 수 있습니다. 개인정보처리자는 전화상으로 개인정보 수집에 대한 동의를 받을 수 있으며, 향후 입증 책임 문제가 발생할 수 있으므로 정보주체의 동의하에 통화내용을 녹취할 수 있습니다.

< 사례 >

- ☞ 영화관 멤버십 카드 발급 시 '개인정보 활용 동의서'에 기명날인하는 경우
- ☞ 공공기관의 인터넷 홈페이지 회원가입 시 개인정보 수집·이용 동의에 체크하는 경우

▶ 필수 고지사항 안내

개인정보처리자는 ①개인정보의 수집·이용목적, ②수집하고자 하는 개인정보의 항목, ③개인정보의 보유 및 이용기간, ④동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우 그 불이익의 내용을 알리고 동의를 받아야 합니다.

개인정보 수집·이용 동의

000는 0000 서비스 회원가입, 고객상담 및 AS, 고지사항 전달 등을 위해 아래와 같이 개인정보를 수집·이용합니다.

수집 목적	수집 항목	보유·이용 기간
회원 식별 및 회원제 서비스 제공	아이디, 비밀번호	00년 00월 00일까지
고객상담 및 AS 관리	전화번호	00년 00월 00일까지
서비스 변경사항 및 고지사항 전달	이메일	00년 00월 00일까지

※ 귀하는 000의 서비스 이용에 필요한 최소한의 개인정보 수집·이용에 동의하지 않을 권리가 있으며, 동의 거부 시 거부한 내용에 대해 서비스가 제한될 수 있습니다.

위 개인정보 수집·이용에 동의합니다. ☒ 동의합니다. ☐ 동의하지 않습니다. ☐

법적 근거

『개인정보 보호법』 제15조(개인정보의 수집·이용)

- 개인정보처리자는 다음 하나에 해당하는 경우에는 개인정보를 수집할 수 있음
 1. 정보주체의 동의를 받은 경우
 2. 법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우 (중략)
- 개인정보처리자는 제1항제1호에 따른 동의를 받을 때에는 다음 각 호의 사항을 정보주체에게 알려야 함
 1. 개인정보의 수집·이용 목적
 2. 개인정보의 보유 및 이용 기간
 3. 수집하려는 개인정보의 항목
 4. 동의 거부권 및 거부에 따른 불이익 내용

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제15조제1항	수집·이용기준을 위반하여 개인정보를 수집한 경우	5천만원 이하 과태료
법 제15조제2항	정보주체에 대한 고지의무를 위반한 경우	3천만원 이하 과태료

2. 개인정보 파기

< 위반 사례 >

- 개인정보를 1년 동안 이용할 것을 정보주체로부터 동의 받았으나, 수집일로부터 1년 2개월이 지나도록 개인정보를 파기하지 않은 사례
→ 개인정보 보유기간이 경과했을 때는 지체 없이 그 개인정보를 파기해야 함
- 파쇄하지 않은 채로 버려진 개인정보 문서를 다른 직원이 이면지로 사용한 사례
→ 개인정보를 파기할 시에는 물리적으로 분쇄하거나 소각하는 방식으로 다시는 재생시킬 수 없도록 파기해야 함

조치 사항 및 방법

▶ 불필요한 개인정보는 지체 없이 파기

개인정보의 처리 목적이 달성되었거나, 해당 서비스의 폐지, 사업이 종료된 경우 **정당한 사유가 없는 한 5일 이내에** 개인정보를 파기하여야 합니다.

< 개인정보가 불필요하게 된 때 >

- ☞ 개인정보처리자가 당초 고지하고 동의를 받았던 보유기간의 경과
- ☞ 동의를 받거나 법령 등에서 인정된 수집·이용·제공 목적의 달성
- ☞ 회원탈퇴, 제명, 계약관계 종료, 동의철회 등에 따른 개인정보처리의 법적 근거 소멸
- ☞ 대금 완제일이나 채권소멸시효기간의 만료

▶ 파기방법

개인정보를 파기할 때에는 다시 복원하거나 재생할 수 없는 형태로 완벽하게 파기하여야 합니다. 하드디스크, CD/DVD, USB 메모리 등의 매체에 **전자기적으로 기록된 개인정보는 다시 재생시킬 수 없는 기술적 방법으로 삭제**하거나 물리적인 방법으로 매체를 파괴하여 복구할 수 없도록 하여야 하며, 종이와 같이 출력물의 형태로 되어 있는 경우에는 물리적으로 분쇄하거나 소각하는 방법으로 해당 개인정보를 완전히 파기하여야 합니다.

▶ 법령상 의무보관 개인정보의 보존방법

법령에 따라 개인정보를 파기하지 않고 보존하는 경우에는 해당 개인정보 또는 개인정보파일을 **다른 개인정보와 DB 혹은 테이블 등을 분리하여 저장·관리**하여야 합니다. 미파기 정보가 기존 개인정보와 혼재되어 있으면 개인정보의 목적 외 이용이나 유출, 오·남용의 위험성이 커지므로 이를 방지하기 위한 규정입니다. 미파기 정보는 오로지 다른 법령에서 보존하도록 한 목적 범위 내에서만 처리해야 합니다.

< 보존의무를 규정하고 있는 입법례 >

☞ 「전자상거래등에서의 소비자보호에 관한 법률」 제6조 및 동 시행령 제6조

- ① 표시·광고에 관한 기록 : 6개월
- ② 계약 또는 청약철회 등에 관한 기록 : 5년
- ③ 대금결제 및 재화등의 공급에 관한 기록 : 5년
- ④ 소비자의 불만 또는 분쟁처리에 관한 기록 : 3년

법적 근거

『개인정보 보호법』 제21조(개인정보의 파기) (요약)

- 개인정보처리자는 보유기간의 경과, 개인정보의 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이 그 개인정보를 파기해야 함. 단, 다른 법령에 따라 보존하여야 하는 경우에는 그렇지 않음
- 개인정보를 파기할 때에는 복구 또는 재생되지 않도록 조치
- 개인정보를 파기하지 아니하고 보존하여야 하는 경우에는 해당 개인정보 또는 개인정보파일을 다른 개인정보와 분리하여서 저장·관리하여야 함

처벌 규정 (벌칙)

3천만원 이하 과태료(제1항), 1천만원 이하 과태료(제3항)

위반 법 조항	위반 내용	처벌 내용
법 제21조제1항	개인정보가 불필요하게 되었을 때 파기하지 않은 경우	3천만원 이하 과태료
법 제21조제3항	개인정보를 분리하여 저장·관리하지 않은 경우	1천만원 이하 과태료

3. 고유식별정보의 처리

< 위반 사례 >

- 고유식별정보 수집·이용에 대한 동의를 다른 개인정보에 대한 동의와 구분하지 않고 한 번에 받은 사례
→ 고유식별정보 수집·이용에 대한 동의는 다른 개인정보와 구분하여 별도로 고지하고 동의 받아야 함
- 다른 법령의 근거 없이 정보주체로부터 동의를 받아 주민등록번호를 수집·이용한 사례
→ 다른 고유식별정보와 달리 주민등록번호는 정보주체의 동의가 있다 해도 법령이 구체적으로 처리를 요구하거나 허용한 경우가 아니면 처리할 수 없음

고유식별정보란?

① 주민등록번호* ② 여권번호 ③ 운전면허번호 ④ 외국인등록번호

조치 사항 및 방법

1. 고유식별정보의 처리 제한

고유식별정보는 원칙적으로 처리할 수 없으나, 고유식별정보(주민등록번호 제외)의 수집 및 이용에 관한 사항을 별도로 고지하고 동의를 받은 경우와, 법령에서 고유식별정보의 처리를 요구하거나 허용한 경우에만 처리할 수 있습니다.

<동의를 별도로 받은 예시>

☐ 개인정보 수집·이용 내역 (필수사항)

수집·이용 항목	수집·이용 목적	보유기간
경력, 자격사항	채용절차 진행, 경력·자격 확인	채용 종료 후 즉시 삭제

※ 위의 개인정보 수집·이용에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 원활한 채용심사를 할 수 없어 채용에 제한을 받을 수 있습니다.

☞ 위와 같이 개인정보를 수집·이용하는데 동의하십니까? ☐ 예 ☐ 아니오

☐ 고유식별정보 수집·이용 내역

항 목	수집목적	보유기간
운전면허번호	운전직 채용 관리	채용 종료 후 즉시 삭제

※ 위의 고유식별정보 처리에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 원활한 채용심사를 할 수 없어 채용에 제한을 받을 수 있습니다.

☞ 위와 같이 고유식별정보를 처리하는데 동의하십니까? ☐ 예 ☐ 아니오

또한, 고유식별정보를 처리하는 경우에는 그 고유식별정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 조치를 하여야 합니다.

2. 주민등록번호의 처리 제한

주민등록번호는 정보주체의 동의를 받았다 하더라도 원칙적으로 처리가 금지되며, 법률·대통령령·국회규칙·대법원규칙·헌법재판소규칙·중앙선거관리위원회규칙 및 감사원규칙에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우에만 처리할 수 있습니다.

< 주민등록번호 처리를 요구·허용하는 법령 예시 >

- ☞ 고등교육법 시행령 제73조(고유식별정보의 처리)
- ☞ 근로자직업능력개발법 시행령 제52조의2(민감정보 및 고유식별정보의 처리)
- ☞ 의료법 시행령 제42조의2(민감정보 및 고유식별정보의 처리)

법적 근거

『개인정보 보호법』 제24조(고유식별정보의 처리 제한) (요약)

- 개인정보처리자는 다음 각 호의 경우를 제외하고는 법령에 따라 개인을 고유하게 구별하기 위하여 부여된 식별정보로서 대통령령으로 정하는 정보(이하 "고유식별정보" 라 한다)를 처리할 수 없다.
 1. 정보주체에게 제15조제2항 각 호 또는 제17조제2항 각 호의 사항을 알리고 다른 개인정보의 처리에 대한 동의와 별도로 동의를 받은 경우
 2. 법령에서 구체적으로 고유식별정보의 처리를 요구하거나 허용하는 경우
- 개인정보처리자가 제1항 각 호에 따라 고유식별정보를 처리하는 경우에는 그 고유식별정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 대통령령으로 정하는 바에 따라 암호화 등 안전성 확보에 필요한 조치를 하여야 한다.

『개인정보 보호법』 제24조의2(주민등록번호 처리의 제한) (요약)

- 제24조제1항에도 불구하고 개인정보처리자는 다음 각 호의 어느 하나에 해당하는 경우를 제외하고는 주민등록번호를 처리할 수 없다.(중략)
- 개인정보처리자는 제24조제3항에도 불구하고 주민등록번호가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 암호화 조치를 통하여 안전하게 보관하여야 한다.(중략)

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제24조제1항	동의를 받지 않거나 법령근거 없이 고유식별정보를 처리한 경우	5년 이하의 징역 또는 5천만원 이하의 벌금
법 제24조의2제1항	법령근거 없이 주민등록번호를 처리한 경우	3천만원 이하의 과태료
법 제24조제3항, 법 제24조의2제2항	고유식별번호에 대해 안전성 확보에 필요한 조치를 하지 않은 경우	3천만원 이하의 과태료
	주민등록번호가 분실·도난·유출·위조·변조 또는 훼손된 경우(안전성 확보에 필요한 조치를 다 한 경우는 제외)	5억원 이하의 과징금

4. 개인정보 처리 업무 위탁

< 위반 사례 >

- 개인정보 처리가 포함된 업무를 위탁하면서 법률에 따라 위탁 문서를 작성하였으나, 문서 상 '위탁업무의 목적 및 범위' 항목을 누락한 사례
→ 개인정보 처리업무 위탁 시 6가지 필수항목이 포함된 문서에 의하여야 함
- 개인정보를 위탁하는 사실을 홈페이지에 공개하지 않아 적발된 사례
- 홈페이지에 '수탁자'만을 공개하고, '위탁업무의 내용'을 누락한 사례
→ 개인정보 처리업무 위탁 시 '1. 위탁업무 내용, 2. 수탁자'를 홈페이지에 공개해야 함

조치 사항 및 방법

1. 위탁 목적 등의 문서화

개인정보처리자가 제3자에게 개인정보의 처리 업무를 위탁하는 경우에는 다음 각 호의 내용이 포함된 문서에 의하여야 합니다.

위·수탁 문서에 필수적으로 포함되어야 하는 내용	근거
① 위탁업무의 목적 및 범위	시행령\$28①제1호
② 위탁업무 수행 목적 외 개인정보의 처리 금지에 관한 사항	법\$26①제1호
③ 위탁업무와 관련하여 보유하고 있는 개인정보의 관리 현황 점검 등 감독에 관한 사항	시행령\$28①제4호
④ 개인정보의 기술적·관리적 보호조치에 관한 사항 ※ 개인정보에 대한 접근 제한 등 안전성 확보 조치에 관한 사항	법\$26①제2호 시행령\$28①제3호
⑤ 재위탁 제한에 관한 사항	시행령\$28①제2호
⑥ 수탁사가 준수하여야 할 의무를 위반한 경우의 손해배상 등 책임에 관한 사항	시행령\$28①제5호

- ☞ 위·수탁에 대한 자세한 사항은 개인정보보호 종합포털(privacy.go.kr)의 '자료마당'
→ '지침자료'에 "개인정보 처리 위·수탁 안내서"를 참고

2. 위탁업무 내용 등의 공개

개인정보처리자(위탁자)는 ① 위탁하는 업무의 내용과 ② 개인정보 처리 업무를 위탁받아 처리하는 자(수탁자)를 운영 중인 인터넷 홈페이지에 지속적으로 게재하는 방법으로 공개하여야 합니다.

- ※ 홈페이지에 게재할 수 없는 경우 사업장에 공개하는 등 시행령 제31조제3항 각호의 방법으로 공개 가능

위반 및 개선 사례

[위반 사례] 위탁업무내용 미고지

수탁자 명	개인정보의 보유기간
(주) ○○○○	회원탈퇴 시 또는 위탁계약 종료시 까지

[개선 사례] 위탁업무내용 및 수탁자 공개

수탁자 명	위탁업무내용	개인정보의 보유기간
(주) ○○○○	위탁업무 위탁업무내용	회원탈퇴 시 또는 위탁계약 종료시 까지

3. 수탁자에 대한 교육 및 감독

위탁자는 수탁자에 대하여 개인정보보호 교육을 실시하고 위·수탁 문서에 포함된 내용 및 법 제29조의 안전조치의무를 준수하는지 여부 등 개인정보 처리 현황을 감독해야 합니다. 이때, 위탁자는 실질적인 감독을 위하여 감독 계획을 미리 수립하고, 수탁자와 협의하여 자료 제출 요구, 현장 방문, 점검 도구 배포 등 다양한 수단을 활용 할 수 있습니다.

법적 근거

『개인정보 보호법』 제26조(업무위탁에 따른 개인정보의 처리 제한) (요약)

- 개인정보처리자가 제3자에게 개인정보의 처리 업무를 위탁하는 경우에는 다음 각 호의 내용이 포함된 문서에 의하여야 한다.
 - 위탁업무 수행 목적 외 개인정보의 처리 금지에 관한 사항
 - 개인정보의 기술적·관리적 보호조치에 관한 사항
 - 그 밖에 개인정보의 안전한 관리를 위하여 대통령령으로 정한 사항
- 제1항에 따라 개인정보의 처리 업무를 위탁하는 개인정보처리자(이하 "위탁자"라 한다)는 위탁하는 업무의 내용과 개인정보 처리 업무를 위탁받아 처리하는 자(이하 "수탁자"라 한다)를 정보주체가 언제든지 쉽게 확인할 수 있도록 대통령령으로 정하는 방법에 따라 공개하여야 한다.

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제26조제1항	업무 위탁 시 같은 항 각 호의 내용이 포함된 문서에 의하지 않은 경우	1천만원 이하 과태료
법 제26조제2항	위탁하는 업무의 내용과 수탁자를 공개하지 않은 경우	1천만원 이하 과태료

5. 개인정보 안전조치의무 : (1) 개인정보취급자 접근권한 관리

< 위반 사례 >

- 개인정보취급자에게 개인정보처리시스템에 대한 접근권한을 부여하면서, 담당 업무별로 권한을 차등부여하지 않고 모든 개인정보취급자에게 전체 권한을 부여한 사례
 - 개인정보취급자에게 개인정보처리시스템에 접속하는 계정은 업무별로 차등부여 해야 함
- 개인정보취급자의 접근권한 부여, 변경, 말소에 대한 내역을 3년간 보관하지 않은 사례
 - 개인정보취급자에 대한 접근권한 부여, 변경, 말소에 대한 내역은 최소 3년간 보관해야 함

조치 사항 및 방법

1. 취급자별 계정 발급 및 최소한의 권한 차등부여

개인정보처리시스템별 사용자 계정은 개인정보취급자 별로 한 개씩 발급합니다. 접근 권한은 업무별로 접근 가능한 메뉴 및 상세 권한(입력/쓰기/삭제/변경/출력/다운로드)을 세분화하여 최소한으로 차등부여 합니다.

2. 접근권한 부여, 변경, 말소 내역 3년 이상 보관

개인정보처리시스템에 접속할 수 있는 개인정보취급자에 대한 접근 권한 부여, 변경, 말소에 대한 내역은 최소 3년간 보관해야 합니다.

개인정보처리시스템에 대한 접근권한의 기록은 다음과 같은 정보가 포함되도록 관리해야 하며, 권한변경 내역을 누적하여 기록·관리하여야 합니다.

- ① 계정 신청 정보(ID, 사용자), ② 신청일시, ③ 권한 상태(권한 및 생성/변경/말소), ④ 승인자 및 발급자 정보, ⑤ 신청 및 발급 사유

< 위반 및 개선 사례 >

[위반 사례]

- 마지막 권한 변경 내역만 보관

id	name	time	level	req_user	app_user	status
Admin_user1	김**	2017.01.01 14:50	1	User1	Admin	등록
AS_ID1	윤**	2019.06.01 15:53	5	User1	Admin	수정
AS_ID2	이**	2019.01.01 16:20	20	User1	Admin	만료

[개선 사례]

- 모든 권한 변경 이력 보관

id	name	time	level	req_user	app_user	status
Admin_user1	김**	2017.01.01 14:50	1	User1	Admin	등록
AS_ID1	윤**	2018.01.01 11:00	10	User1	Admin	등록
AS_ID2	이**	2018.05.01 11:21	20	User1	Admin	등록
AS_ID1	윤**	2019.06.01 15:53	5	User1	Admin	수정
AS_ID2	이**	2019.01.01 16:20	20	User1	Admin	만료

3. 안전한 비밀번호 작성 규칙 준수

개인정보취급자의 계정 비밀번호가 안전하게 생성될 수 있도록, 개인정보처리자는 비밀번호 작성규칙을 수립하고 이를 개인정보처리 시스템, 접근통제시스템, 인터넷 홈페이지 등에 적용해야 합니다.

비밀번호는 정당한 접속 권한을 가지지 않는 자가 추측하거나 접속을 시도하기 어렵도록 문자, 숫자 등으로 조합·구성하여야 합니다.

4. 비밀번호 오입력 횟수 제한

개인정보처리시스템에 권한 없는 자의 비정상적인 접근을 방지하기 위하여 계정 정보 또는 비밀번호를 일정 횟수 이상 잘못 입력한 경우, 개인정보처리시스템에 접근을 제한하는 등 기술적 조치를 취해야 합니다.

계정정보 또는 비밀번호를 일정 횟수(예: 5회) 이상 잘못 입력한 경우 사용자계정 잠금 등의 조치를 취하거나 계정정보·비밀번호 입력과 동시에 추가적인 인증수단(공인인증서, OTP 등)을 적용하여 정당한 접근 권한 자임을 확인하는 등의 조치를 취하도록 합니다.

법적 근거

『개인정보 안전성 확보조치 기준』 제5조(접근 권한의 관리) (요약)

- 개인정보취급자 등에게 업무수행에 필요한 최소한의 범위로 접근권한의 부여, 변경 또는 말소에 대한 내역을 기록 및 보관
- 개인정보취급자 등에 대한 비밀번호 작성규칙 수립 및 적용 등

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제29조	안전성 확보 조치를 취하지 아니하여 개인정보를 도난·유출·변조 또는 훼손당한 경우	2년 이하 징역 또는 2천만원 이하 벌금
법 제29조	안전성 확보조치 의무를 위반한 경우	3천만원 이하 과태료

5. 개인정보 안전조치의무 : [2] 비인가자 접근통제

< 위반 사례 >

- 개인정보처리시스템에 접속 후 일정시간 이상 업무를 처리하지 않는 경우 자동으로 시스템 접근 차단(로그아웃 등) 조치를 적용하지 않은 사례
 - 개인정보처리시스템에 접속 후 일정시간 이상 업무를 하지 않는 경우 자동으로 시스템 접속이 차단되도록 해야 함
- 외부망에서 개인정보처리시스템에 접속하는 경우 아이디, 비밀번호 이외에 별도의 안전한 접속수단 및 인증수단을 적용하지 않은 사례
 - 외부망에서 개인정보처리시스템에 접속 시 안전한 접속수단 또는 안전한 인증수단을 적용해야 함

조치 사항 및 방법

1. 방화벽 및 침입탐지시스템 운영

개인정보처리시스템에 대한 접속 권한을 제한하여 인가받지 않은 접근을 제한하고, 개인정보처리시스템에 불법적인 개인정보 유출 시도를 탐지하고 접근 제한·차단 등 적절한 대응 조치를 해야 합니다.

불법적인 접근 및 침해사고 방지를 위해 가령 신규 취약점 또는 침해사고 발생 시 보안 업데이트 적용, 과도하게 허용되거나 사용되지 않는 정책 등에 대해 주기적 검토 및 조치, 동일 IP, 해외 IP 주소에서의 과도한/비정상적인 접속 시도 탐지 및 차단조치 등 적절한 운영·관리가 필요합니다.

2 개인정보 접근통제 조치

개인정보처리시스템은 원칙적으로 외부 접근을 차단해야 하며, 업무상 외부에서 개인정보처리시스템에 접속이 필요한 경우에는 ID/PW이외에 안전한 접속 수단(VPN 또는 전용선)을 적용하거나 안전한 인증수단(인증서, 보안토큰, OTP 등)을 적용하여야 합니다.

홈페이지를 통해 개인정보를 처리하는 경우, 개인정보가 유출되지 않도록 정기적으로 웹 취약점 점검을 수행할 것을 권고 합니다. 취약점 점검 시, 관리자 페이지도 반드시 포함되도록 합니다.

업무상 P2P, 공유설정, 상용 웹메일, 웹하드, 메신저, SNS 등은 원칙적으로 사용하지 않도록 하며, 반드시 필요한 경우라도 개인정보가 유·노출되지 않도록 안전조치를 해야 합니다.

개인정보가 포함된 파일, 관리자 페이지, 서블릿 등에 접속하는 경로(URL, 공유설정, P2P 등)에 대한 인증 절차가 적용되어 있는지 확인합니다.

일정시간 이상 업무를 처리하지 않는 경우 자동으로 시스템 접속이 차단되어야 하며, 로그아웃 후에는 개인정보에 대한 접근이 불가능하도록 조치해야 합니다.

< 위반 및 개선 사례 >

[위반 사례]	[개선 사례]
안전한 인증수단 미적용 	안전한 인증수단 적용 

법적 근거

『개인정보 안전성 확보조치 기준』 제6조(접근 통제) (요약)

- 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 침입차단, 침입탐지 기능을 포함한 조치
- 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하는 경우 안전한 접속수단 또는 안전한 인증수단의 적용
- 개인정보 유·노출 방지를 위한 업무용 컴퓨터 등에 대한 안전조치
- 고유식별정보를 처리하는 인터넷 홈페이지에 대한 취약점 점검 및 개선조치 등

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제29조	안전성 확보 조치를 취하지 아니하여 개인정보를 도난·유출·변조 또는 훼손당한 경우	2년 이하 징역 또는 2천만원 이하 벌금
법 제29조	안전성 확보조치 의무를 위반한 경우	3천만원 이하 과태료

5. 개인정보 안전조치의무 : (3) 고유식별정보 암호화

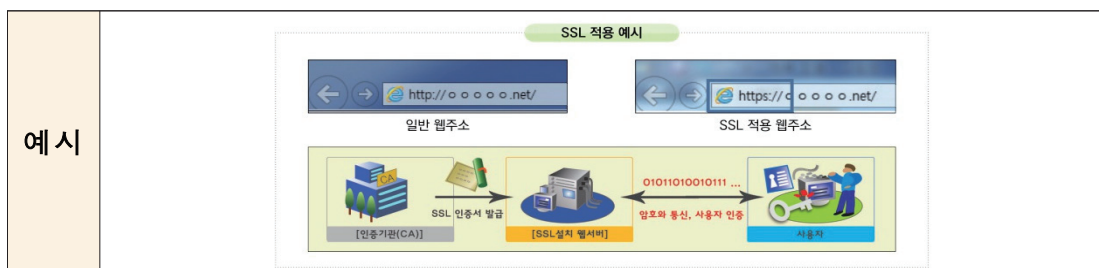
< 위반 사례 >

- 홈페이지에서 여권번호를 입력·전송 시 전송구간 암호화를 적용하지 않은 사례
→ 고유식별정보(주민등록번호, 여권번호, 외국인등록번호, 운전면허번호) 전송 시 SSL등을 적용하여 암호화하여 전송해야 함
- 내부망에 주민등록번호 저장 시 암호화 하지 않고 평문으로 저장한 사례
→ 주민등록번호 등 고유식별정보는 저장 시 안전한 암호화 알고리즘으로 암호화 하여 저장해야 함

조치 사항 및 방법

1. 고유식별정보 전송구간 암호화

정보통신망을 통하여 고유식별정보를 송신하는 경우에는 SSL 등의 통신 암호화프로토콜이 탑재된 기술을 활용하여야 합니다.



또한, 보조저장매체를 통해 고유식별정보가 담긴 파일을 전달하는 경우에는 암호화 기능을 제공하는 보안 USB 등을 사용하거나, 해당 개인정보를 암호화 저장한 후 보조저장매체에 저장하여 전달하여야 합니다.

2. 내·외부망에 고유식별정보 저장 시 암호화

인터넷 구간이나 DMZ 구간은 외부에서 직접 접근이 가능하므로 외부자의 침입을 받을 가능성이 있습니다. 이에 따라 DMZ 구간에서 주민등록번호, 외국인등록번호, 운전면허번호, 여권번호 등 고유식별정보를 처리하는 경우 암호화하여 저장하여야 합니다.



내부망에 고유식별정보를 저장하는 경우에도 역시 암호화하여 저장하여야 합니다.

3. 고유식별정보 안전한 알고리즘으로 암호화 저장

고유식별정보를 암호화하는 경우에는 국내외 암호 관련 연구기관에서 권고하는 안전한 알고리즘으로 암호화하여 저장하여야 합니다.

☞ 안전한 암호화 알고리즘은 개인정보보호 종합포털(privacy.go.kr)의 ‘자료마당’ → ‘참고자료’에 ‘개인정보의 암호화 조치 안내서’ 참고

법적 근거

『개인정보 안전성 확보조치 기준』 제7조(개인정보의 암호화) (요약)

- 고유식별정보를 정보통신망을 통해 송신하거나 보조저장매체를 통해 전달하는 경우 암호화
- 비밀번호를 저장하는 경우 일방향 암호화하여 저장
- 인터넷구간 및 인터넷구간과 내부망의 중간지점(DMZ)에 고유식별정보를 저장하는 경우 암호화
- 내부망에 고유식별정보를 저장하는 경우에도 암호화하여 저장
- 개인정보를 암호화하는 경우 안전한 알고리즘으로 암호화하여 저장

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제29조	안전성 확보 조치를 취하지 아니하여 개인정보를 도난·유출·변조 또는 훼손당한 경우	2년 이하 징역 또는 2천만원 이하 벌금
법 제29조	안전성 확보조치 의무를 위반한 경우	3천만원 이하 과태료

5. 개인정보 안전조치의무 : (4) 비밀번호 암호화

< 위반 사례 >

- 홈페이지 회원가입 및 로그인 페이지 등 비밀번호를 입력·전송 시 전송구간 암호화를 적용하지 않은 사례
 - 비밀번호 전송 시 SSL등을 적용하여 암호화하여 전송해야 함
- 비밀번호 저장 시 암호화 하지 않고 평문으로 저장한 사례
 - 비밀번호는 저장 시 안전한 암호화 알고리즘으로 암호화하여 저장해야 하며, 암호화 시 일방향 암호화 알고리즘으로 암호화 해야 함

조치 사항 및 방법

1. 비밀번호 전송구간 암호화

정보통신망을 통하여 비밀번호를 송신하는 경우에는 SSL 등의 통신 암호화프로토콜이 탑재된 기술을 활용하여야 합니다. 패킷 캡처 프로그램 등을 통해 전송되는 패킷의 내용을 확인하여 비밀번호 등이 평문으로 전송되는지 확인하여야 합니다.

예시

No.	Time	Source	Destination	Protocol	Length	Info
72	39.222544000	192.168.1.119	125.209.206.19	TCP	66	5954→443 [SYN] Seq=0 Win=0 Len=0
73	39.229957000	125.209.206.19	192.168.1.119	TCP	66	443→5954 [ACK] Seq=5954 Win=0 Len=0
74	39.230071000	192.168.1.119	125.209.206.19	TCP	54	5954→443 [ACK] Seq=1157 Win=0 Len=0
75	39.230283000	192.168.1.119	125.209.206.19	TLSv1.2	298	Client hello
76	39.235485000	125.209.206.19	192.168.1.119	TLSv1.2	219	Server hello, change cipher spec
77	39.235886000	192.168.1.119	125.209.206.19	TLSv1.2	129	Change cipher spec
78	39.237214000	192.168.1.119	125.209.206.19	TLSv1.2	891	Application data
79	39.245384000	125.209.206.19	192.168.1.119	TCP	66	443→5954 [ACK] Seq=1157 Win=0 Len=0
80	39.332437000	125.209.206.19	192.168.1.119	TLSv1.2	907	Application data
81	39.381521000	192.168.1.119	125.209.206.19	TCP	54	5954→443 [ACK] Seq=1157 Win=0 Len=0
83	84.332600000	192.168.1.119	125.209.206.19	TCP	55	TCP keep-alive 5954→443
84	84.338623000	125.209.206.19	192.168.1.119	TCP	66	TCP keep-alive ack 443

※ 로그인 시 SSL/TLS 암호화를 사용하여 비밀번호 전송

2. 안전한 일방향 암호화 알고리즘을 사용하여 저장

비밀번호를 암호화할 때는 한번 암호화된 뒤 복호화되지 않도록 일방향 암호화하여야 합니다. 일방향 암호화란 해시함수로 암호화하여 원본 값을 유추하거나 복호화할 수 없도록 한 암호화 방법입니다.

비밀번호를 저장할 경우 안전하지 않은 일방향 암호화 알고리즘(MD5, SHA1, 자체제작함수 등)으로 암호화 하는 경우 복호화 될 위험이 있으므로, 반드시 안전한 일방향 암호화 알고리즘(SHA256, SHA512 등)으로 암호화하여야 합니다.

☞ 안전한 암호화 알고리즘은 개인정보보호 종합포털(privacy.go.kr)의 ‘자료마당’ → ‘지침자료’에 ‘개인정보의 암호화 조치 안내서’ 참고

< 위반 및 개선 사례 >

[위반 사례]

●비밀번호 MD5 적용

PWD
87dd634732708e62d971a97b2a2b0b59
3e3bbe47bc5855968bd27892908394e9
0ab0f5f239a29474b916cf1cf3ff8c36
c54fb1bf6d11cb26d1bf0a190009dbd1
1b4f4da6aa2b36c81f4f56e4e287653b
aafc8ad0eeb08550ae74fcb25009c1

[개선 사례]

●안전한 알고리즘인 SHA256 적용

USERPWD
ac287b2a00afd2e4c885b41f2abc97680349ca1b7cdb8d82b6c4ad5b451247a2
a167093600dbb055607ccf0b8ac09e4609526d81833d2ea2d0bd8fdef2d25d27
dac690a6df14973d7a1ee5873f5f85103528340e5655755cd3ff37cbabc2c6f3
6463ec0b533c3e42689e295f0eb0765a8d690a8fdae0abe75d7a0b64e77907ad
a5a852f579114455a419102dfcd7a68806a1702d8521edf1d940b088968b1c8

법적 근거

『개인정보 안전성 확보조치 기준』 제7조(개인정보의 암호화) (요약)

- 비밀번호를 정보통신망을 통해 송신하거나 보조저장매체를 통해 전달하는 경우 암호화
- 비밀번호를 저장하는 경우 복호화되지 않도록 일방향 암호화하여 저장
- 비밀번호를 암호화하는 경우 안전한 알고리즘으로 암호화

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제29조	안전성 확보 조치를 취하지 아니하여 개인정보를 도난·유출·변조 또는 훼손당한 경우	2년 이하 징역 또는 2천만원 이하 벌금
법 제29조	안전성 확보조치 의무를 위반한 경우	3천만원 이하 과태료

5. 개인정보 안전조치의무 : ⑤ 접속기록 보관 및 관리

< 위반 사례 >

- 개인정보취급자의 접속기록을 보관하고 있으나, 수행업무(조회, 수정 등)에 대한 내용을 기록하지 않은 사례
 - 개인정보취급자의 접속기록을 보관할 때에는 계정, 접속일시, 접속지정보, 수행업무에 대한 내용을 기록하고 보관해야 함
- 법적 의무사항을 모두 포함한 개인정보취급자의 접속기록을 보관하고 있으나, 3개월만 보관한 사례
 - 개인정보취급자의 접속기록은 최소 1년 이상 보관해야 함

조치 사항 및 방법

1. 접속기록 1년 이상 보관

개인정보처리시스템 기획 단계에서부터 개인정보취급자가 접속한 사실을 알 수 있는 아래 정보가 시스템에 전자적으로 자동 기록되도록 설계·구현하여야 합니다.

- ① 계정(ID 등) : 시스템에 접속한 자를 식별할 수 있도록 부여된 정보
- ② 접속일시(년-월-일-시-분-초) : 접속한 시점 또는 업무를 수행한 시점
- ③ 접속지(IP주소 등) : 접속한 취급자의 컴퓨터, 모바일기기 등 주소
- ④ 정보주체정보 : 개인정보취급자가 누구의 개인정보를 처리하였는지를 알 수 있는 이름, ID 등
- ⑤ 수행업무(저장, 수정, 삭제, 다운로드 등) : 취급자가 시스템에서 처리한 정보 주체에 관한 수행업무 내용을 알 수 있는 정보

예시	번호	계정정보	접속일자	접속시간	접속지정보	수행업무	정보주체
	1001	K1234	2019-02-01	10:05:15	192.168.*.***	다운로드	AB1234

※ 수행업무 중 다운로드의 경우 그 사유를 반드시 기록하여야 합니다.

또한, 접속기록은 생성되는 시기에 따라 아래 기간 동안 보관하여야 합니다.

구분	보관기간
모든 개인정보처리시스템	1년 이상
5만명 이상 개인정보 처리 또는 고유식별정보 및 민감정보 처리시스템	2년 이상

2. 접속기록 월 1회 이상 점검

개인정보처리시스템에 보관된 접속기록을 최소 월 1회 이상 점검하여 비정상 행위를 탐지하고 적절한 대응조치를 하여야 합니다.

체계적인 점검을 수행하고 점검의 효율성을 확보하기 위해서는 아래와 같은 사항 등을 사전에 계획하고 시행할 수 있습니다.

- ① 점검 주체(개인정보보호 부서, 감사부서, 개인정보보호 전문업체 등)
- ② 점검 시기(최소 월 1회 이상)
- ③ 점검 항목 및 내용(비인가된 개인정보 처리 및 대량의 개인정보 다운로드 등 비정상 행위 탐지, 접속기록의 위·변조 여부 등) 등
- ④ 점검 후속조치(개선조치, 결과 보고 등) 등

3. 접속기록을 안전하게 보관

접속기록이 위·변조 및 도난, 분실되지 않도록 아래와 같은 방법 등으로 안전하게 보관 하여야 합니다.

- ① 접속기록을 상시 백업하여 별도의 보조저장매체, 저장장치 등에 보관
- ② CD-ROM, DVD-R, WORM 등과 같은 덮어쓰기 방지 매체 사용
- ③ 접속기록을 수정 가능한 매체(하드디스크 등)에 백업하는 경우에는 위·변조 여부를 확인할 수 있는 정보를 별도의 장비에 보관 등

법적 근거

『개인정보 안전성 확보조치 기준』 제8조(접속기록의 보관 및 점검) (요약)

- 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상 보관
- 개인정보처리시스템의 접속 기록 등을 월 1회 이상 점검
- 개인정보취급자의 접속기록을 안전하게 보관

처벌 규정 (벌칙)

위반 법 조항	위반 내용	처벌 내용
법 제29조	안전성 확보 조치를 취하지 아니하여 개인정보를 도난·유출·변조 또는 훼손당한 경우	2년 이하 징역 또는 2천만원 이하 벌금
법 제29조	안전성 확보조치 의무를 위반한 경우	3천만원 이하 과태료

붙임

주의해야할 개인정보 유출사례 - 관리자 부주의로 인한 유출

유출 사례(1) - 메일 단체발송에 의한 유출

- ▶ 기업에서 채용 응시생들에게 이메일을 통해 불합격 통보를 하는 과정에서 수백명의 응시생에게 이메일을 동보발송 하여 통보를 받은 응시생들에게 다른 불합격자들의 이메일 주소가 그대로 노출된 사례
- ▶ 해당 기업이 수백명의 불합격자가 다른 불합격자들의 이메일 주소를 취득할 수 있도록 일괄적으로 이메일을 발송한 것은 개인정보보호 의무를 다하였다고 보기 어렵고, 불합격자들이 자신들의 의사에 반하여 개인정보가 함부로 공개되지 아니할 권리가 침해되었다고 볼 수 있습니다.

따라서 채용결과 통보, 공문발송 등 여러 명의 정보주체에게 동일한 내용을 전달하는 경우에는 수신자 개개인의 개인정보가 공개되지 않도록 주의(개별발송 기능 의무사용 등)하여야 합니다.

< 개선 사례 >

원하는 옵션선택 후 확인버튼을 클릭하세요.

개별발송 ☒ 사용 ☐ 사용안함 | ☐ 설정유지

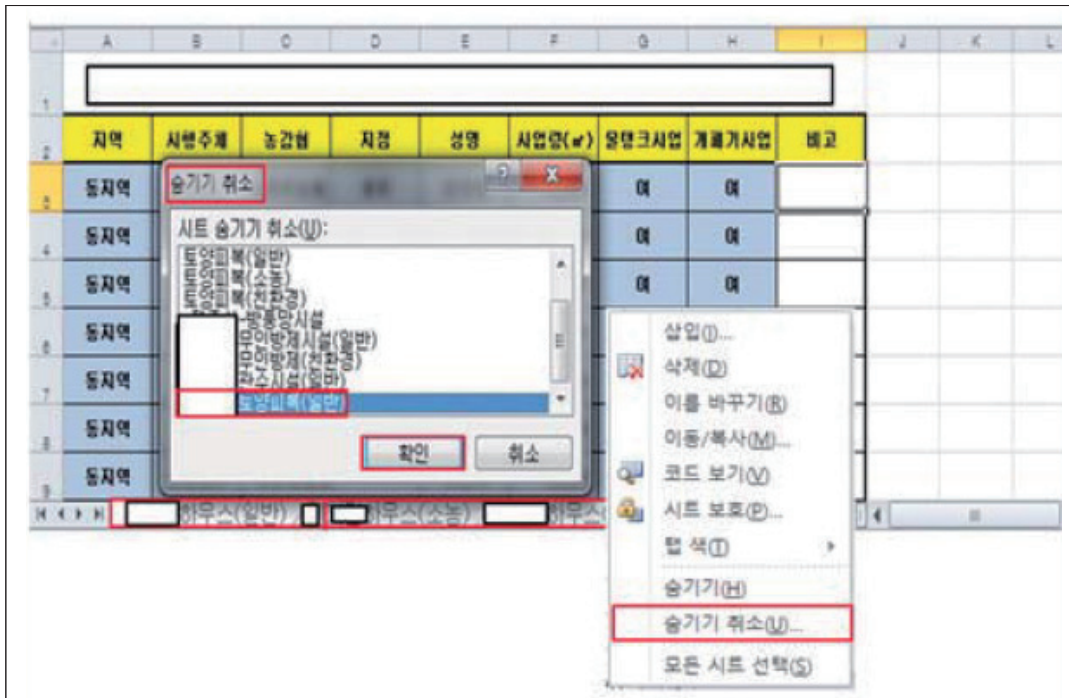
보내는 사람: 김...@...
받는 사람: ...
참조: ...
숨은참조: ...
제목: [말머리 선택] 개별발송 기능을 통한 이메일 발송

※ 메일시스템의 개별발송 기능을 사용하여 동보발송 사고 방지

유출 사례(2) - 게시판 업로드로 인한 유출

- ▶ 민간 협회에서 협회 운영실적에 관한 자료를 홈페이지 게시판에 업로드하는 과정에서 개인정보취급자가 엑셀파일에서 주민등록번호가 포함된 행/열이 ‘숨기기’ 처리된 것을 인지하지 못하고 잘못 업로드 하여 검색엔진에 의해 노출된 사례
- ▶ 엑셀파일 업로드 시 ‘숨기기’ 처리된 행/열 또는 Sheet가 있는지 확인하고, 개인정보가 포함되어 있을 경우 삭제 조치하여 개인정보가 노출되지 않도록 하여야 합니다.

< 개선 사례 >



※ ‘숨기기 취소’ 기능을 사용하여 숨겨진 Sheet에 개인정보가 포함되어 있는지 확인

- ▶ 자세한 개인정보 노출 사례 및 조치방법은 ‘홈페이지 개인정보 노출 방지 안내서’ 참고

개인정보 보호조치 안내서 (주요 위반·개선 사례 중심)

발 행 일 2020. 12.

발 행 처 개인정보보호위원회 한국인터넷진흥원

디자인·인쇄 한결엠 02-6952-0551

 중증장애인생산품생산시설

 사회적협동조합

 사회적기업